

JOYKIN

เอกสารอธิบายระบบแอป Joykin

สถาปัตยกรรม ขั้นตอนการทำงาน หลักการส่ง ระบบห้อง และองค์ประกอบทั้งหมด

โครงการ what2eat หรือ Joykin

Branch v1ice

วันที่จัดทำ 2026-09-22

บทสรุปของระบบ

Joykin เป็นแอปมือถือสำหรับช่วยเลือกอาหาร ทั้งการสุ่มคนเดียวและการโหวตร่วมกันในห้อง Party ผู้ใช้เลือกเมนูจากรายการระบบ เพิ่มเมนูส่วนตัว ช้อนเมนูที่ไม่ต้องการ เก็บเมนูโปรด ดูประวัติ และเปิดแผนที่หาร้านใกล้เคียงปัจจุบันได้

แอปพัฒนาด้วย Expo SDK 57 และ React Native เชื่อม Supabase สำหรับ Auth ฐานข้อมูล Postgres Storage Edge Functions และ Realtime การควบคุมสิทธิ์หลักอยู่ที่ Row Level Security และฟังก์ชันฐานข้อมูล ไม่ได้พึ่งการเชื่อมปมบนหน้าจอเพียงอย่างเดียว

ระบบสุ่ม Solo ใช้การสุ่มแบบโอกาสเท่ากันจากรายการที่ผ่านตัวกรอง ส่วน Party ไม่ได้สุ่มผู้ชนะทันที แต่ให้ทุกคนโหวตทุกเมนู แล้วเลือกเฉพาะเมนูที่ทุกคนกดชอบ หากมีหลายเมนูที่ผ่าน ระบบฐานข้อมูลจะสุ่มเลือกหนึ่งเมนูจากกลุ่มนั้น

โฆษณาใช้การสุ่มแบบถ่วงน้ำหนักตามยอดชำระ โฆษณาที่มียอดชำระมากกว่าจะมีโอกาสปรากฏมากกว่า แต่ทุกโฆษณายังเปิดใช้งานและอยู่ในช่วงเวลาที่กำหนดยังมีโอกาสถูกเลือก

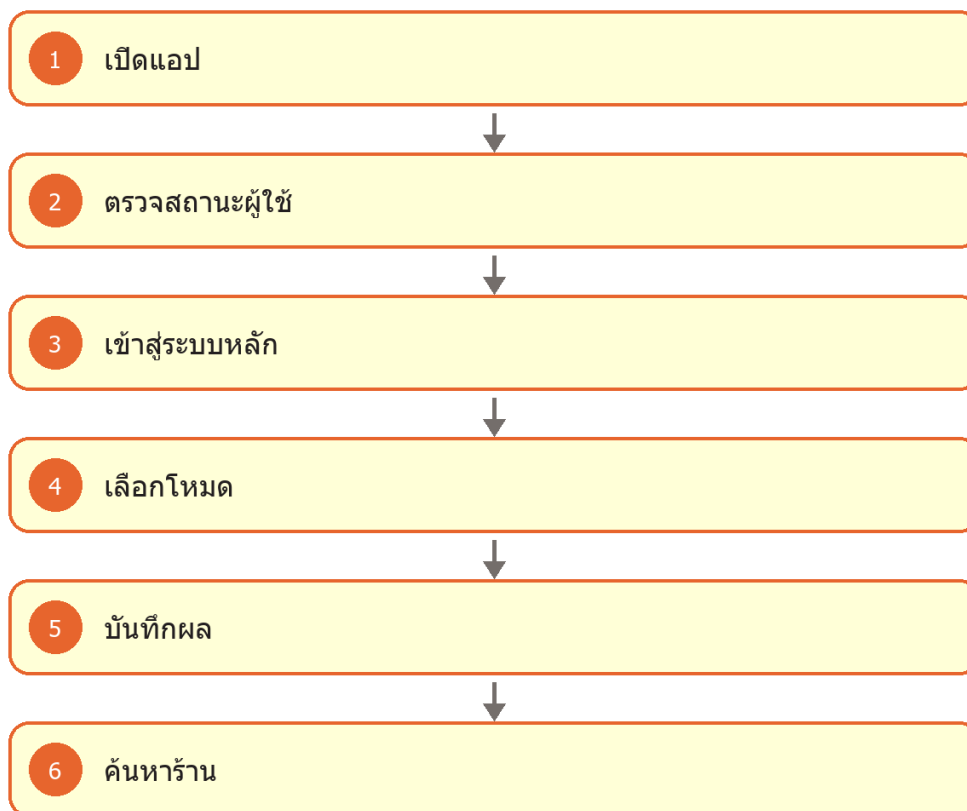
ขอบเขตและที่มาของเอกสาร

เอกสารนี้อธิบายการทำงานจากซอร์สโค้ด Branch v1ice และตรวจโครงสร้าง Supabase ที่ใช้งานจริง ณ วันที่ 22 กันยายน 2026 เนื้อหาครอบคลุมหน้าจอ การรับส่งข้อมูล หลักการสุ่ม ฐานข้อมูล สิทธิ์ ความเสถียร ข้อจำกัด และวิธีรันระบบ

- ซอร์สโค้ดใน Branch v1ice
- Schema และข้อมูลโครงสร้างจาก Supabase โปรเจกต์ what2eat-backend
- ผลทดสอบอัตโนมัติ Expo Doctor และ Android bundle ล่าสุด

ภาพรวมขั้นตอนการทำงาน

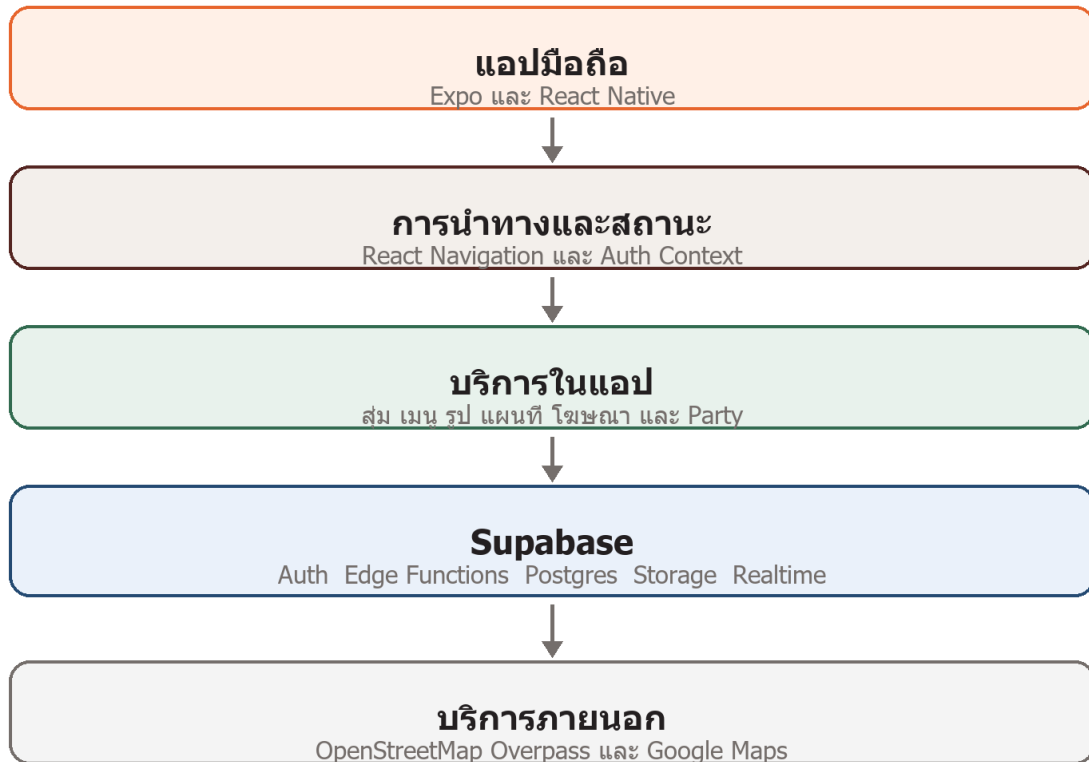
Flow การใช้งานหลัก



ขั้น	กระบวนการ	รายละเอียด
1	เปิดแอป	AuthProvider ตรวจสอบ session ที่เก็บใน SecureStore และโหลดโปรไฟล์จาก public.users
2	ตรวจสอบสถานะผู้ใช้	ถ้าไม่มี session จะแสดง Login Register และ Verify Email ถ้ามี session จะแสดง Main Tabs
3	เข้าสู่ระบบหลัก	ผู้ใช้เข้าหน้าแรก ค้นหา สุ่มเมนู ดูรายการโปรด หรือจัดการบัญชี
4	เลือกโหมด	สุ่มทันทีบนหน้าแรก ใช้ Solo พร้อมตัวกรอง หรือสร้าง Party เพื่อโหวดร่วมกัน
5	บันทึกผล	ผล Solo และ Party ถูกบันทึกใน history และสามารถบันทึก favorites เพิ่มเดิมได้
6	ค้นหาร้าน	ส่งชื่อเมนูไป NearbyMap ขอ GPS ดึงร้านจาก OpenStreetMap จัดอันดับ และเปิดเส้นทางใน Google Maps

สถาปัตยกรรมและเทคโนโลยี

สถาปัตยกรรม Joykin



ชั้น	เทคโนโลยี	หน้าที่
ส่วนติดต่อผู้ใช้	React Native และ Expo SDK 57	หน้าจอมือถือ การป้อนข้อมูล การดิสคัม โมเดล แผนที่ และแอนิเมชัน
การนำทาง	React Navigation 7	แยก Signed out Stack, Signed in Stack และ Bottom Tabs
สถานะบัญชี	React Context	เก็บ user, loading, error และฟังก์ชัน login register guest logout
Client Backend	supabase-js 2.116.0	เรียก Auth Data API RPC Storage Realtime และ Edge Functions
ตรรกะเซิร์ฟเวอร์	Supabase Edge Functions และ PostgreSQL RPC	สมัครสมาชิก ล็อกอิน ย้ายบัญชีเก่า สร้างห้อง โหวต และสรุปผลแบบ atomic
ข้อมูล	Supabase Postgres 17	บัญชี เมนู รายการโปรด ประวัติ ห้อง คะแนนโหวต โฆษณา และค่าความชอบ
ไฟล์	Supabase Storage	รูปเมนู รูปโปรไฟล์ และรูปโฆษณา
ข้อมูลสด	Supabase Realtime และ polling	แจ้งให้แอปโหลด snapshot ห้องใหม่ และสำรวจด้วย polling ทุก 2 วินาที
บริการภายนอก	Expo Location OpenStreetMap Overpass และ Google Maps	ตำแหน่ง ร้านใกล้เคียง การจัดอันดับ และการนำทาง

รายการเทคโนโลยี

องค์ประกอบ	เวอร์ชันหรือแพ็คเกจ	การใช้งาน
Expo	57.0.24	รันแอปบน Android iOS และ Web ผ่าน Metro
React	19.2.3	Component และ State
React Native	0.86.3	UI และ Native APIs
React Navigation	7.x	Stack และ Bottom Tabs
Supabase JS	2.116.0	Auth Database RPC Storage Realtime และ Functions
Expo SecureStore	57.0.4	เก็บ session บนมือถือ
Expo Image Picker	57.0.19	เลือกรูปและเปิดกล้อง
Expo Location	57.0.19	GPS และ Reverse Geocoding
React Native Maps	1.27.2	แสดงแผนที่และ Marker
PostgreSQL	17.6	ฐานข้อมูลและดรกรกะ Party

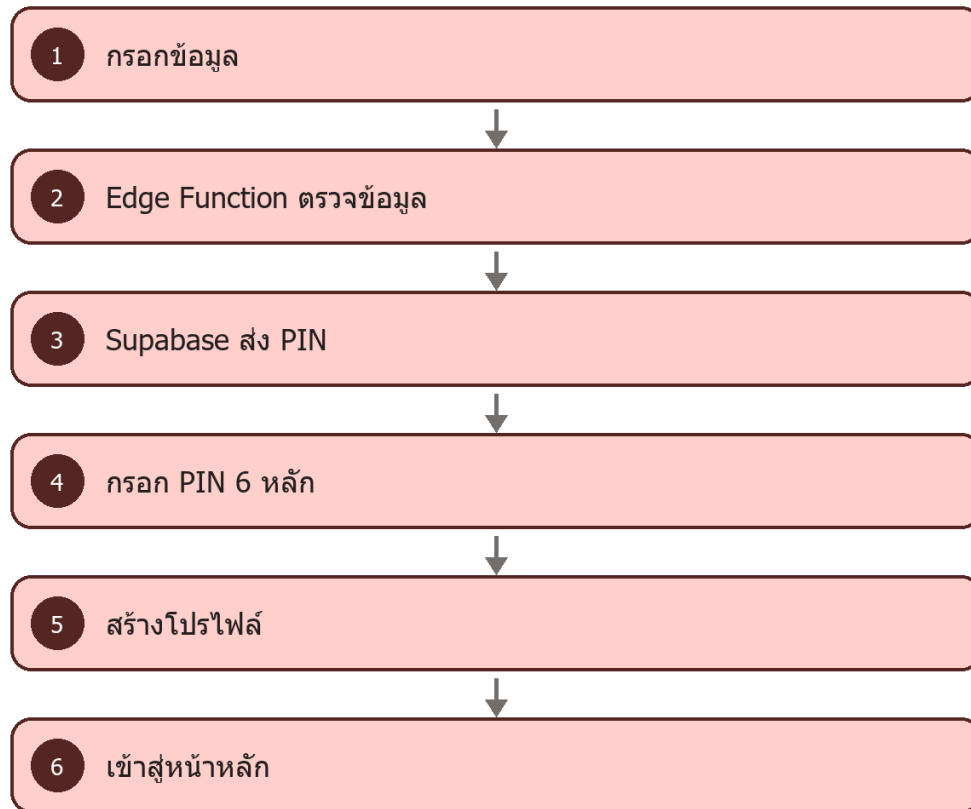
โครงสร้างการนำทางและหน้าจอ

AppNavigation แบ่งเส้นทางตามสถานะ user หากยังไม่มี session จะเข้ากลุ่ม Signed out เมื่อ AuthProvider โหลดโปรไฟล์สำเร็จ Navigation จะสลับทั้งกลุ่มเป็น Signed in โดยใช้ user id เป็น navigation key

กลุ่ม	หน้าจอ	หน้าที่
ยังไม่เข้าสู่ระบบ	Login	เข้าสู่ระบบด้วย Username หรือ Email และ Password หรือใช้ Guest
ยังไม่เข้าสู่ระบบ	Register	สร้างบัญชีโดยอีเมลเป็นตัวเลือก
ยังไม่เข้าสู่ระบบ	VerifyEmail	กรอก PIN 6 หลักและส่งรหัสใหม่หลัง 30 วินาที
แท็บหลัก	Home	ภาพรวม สุ่มด่วน โฆษณา แผนที่ Party และทางลัด
แท็บหลัก	Search	ค้นหาเมนูระบบและเมนูส่วนตัวแบบ debounce 400 ms
แท็บหลัก	Solo	กรอง เลือก และสุ่มเมนู รวมทั้งเพิ่มเมนูส่วนตัว
แท็บหลัก	Favorites	ดูและลบเมนูโปรด
แท็บหลัก	Account	โปรไฟล์ รูป ชื่อ Logout และเมนู Admin
หน้ารอง	Party Lobby Swipe Result	สร้างหรือเข้าห้อง รอผู้เล่น โหวต และดูผล
หน้ารอง	History AllFoods NearbyMap AdminAds	ประวัติ CRUD เมนู แผนที่ และ CRUD โฆษณา

ระบบสมัครสมาชิกและเข้าสู่ระบบ

Flow สมัครสมาชิกด้วย Email



สมัครสมาชิกโดยใช้อีเมล

1. ผู้ใช้กรอกชื่อที่แสดง Username Email และ Password
2. หน้าจอตรวจสอบ Username 3 ถึง 30 ตัว Password อย่างน้อย 12 ตัวและไม่เกิน 72 bytes และรูปแบบ Email
3. AuthContext เรียก Edge Function account-register โดยไม่ส่ง service role key ไปยังแอป
4. Edge Function จำกัด request 4096 bytes ตรวจสอบข้อมูล และใช้ registration_attempt จำกัด 5 ครั้งต่อ 15 นาทีต่ออุปกรณ์ พร้อมเพดานรวม 100 ครั้งต่อนาที
5. Edge Function ตรวจสอบชื่อหรืออีเมลซ้ำ แล้วเรียก Supabase Auth signUp
6. Supabase ส่ง Email OTP โดยเพิ่มฟิลด์ใช้ Token แทน ConfirmationURL
7. แอปเปิด VerifyEmail ให้กรอก PIN 6 หลัก และเรียก verifyOtp ด้วย type email
8. Trigger provision_user สร้าง public.users เมื่อ email_confirmed_at มีค่าแล้วเท่านั้น
9. Auth state เปลี่ยน แอปโหลดโปรไฟล์ และนำเข้าสู่ Main Tabs

สมัครสมาชิกโดยไม่ใช้อีเมล

1. ผู้ใช้เว้น Email วางและส่งฟอร์ม
2. Edge Function สร้างอีเมลภายในโดเมน accounts.joykin.invalid
3. Admin Auth API สร้างผู้ใช้แบบ email_confirm true
4. Trigger สร้างโปรไฟล์ทันที จากนั้น Edge Function signIn และส่งเฉพาะ access token กับ refresh token กลับแอป
5. แอป setSession แล้วเข้าสู่ระบบทันที โดยผู้ใช้ไม่ต้องยืนยัน Email

เข้าสู่ระบบ

1. ผู้ใช้กรอก Username หรือ Email และ Password
2. Edge Function account-login ทำ normalization และ rate limit
3. ระบบตอบข้อความผิดพลาดแบบเดียวและหน่วงอย่างน้อยประมาณ 500 ms เพื่อลดการเดาบัญชีจากข้อความหรือเวลา
4. ถ้าเป็นบัญชีเก่าที่มี password_hash ระบบเปรียบเทียบกับ bcrypt ผังเชิร์ฟเวอร์และย้ายเข้า Supabase Auth
5. Supabase Auth ตรวจสอบ Password ถ้า Email ยังไม่ยืนยัน ระบบ resend OTP และส่งผู้ใช้ไปหน้า VerifyEmail
6. ถ้าสำเร็จ แอป setSession และ AuthProvider โหลดโปรไฟล์

บัญชี Guest

1. Login เรียก signInAnonymously
2. Trigger สร้างโปรไฟล์ Guest อัตโนมัติ
3. Guest ใช้ฟังก์ชันหลักได้ แต่แก้ไขและรูปโปรไฟล์ไม่ได้
4. บัญชี Anonymous ยังใช้บทบาทฐานข้อมูล authenticated จึงต้องอาศัย ownership policy ทุกตาราง

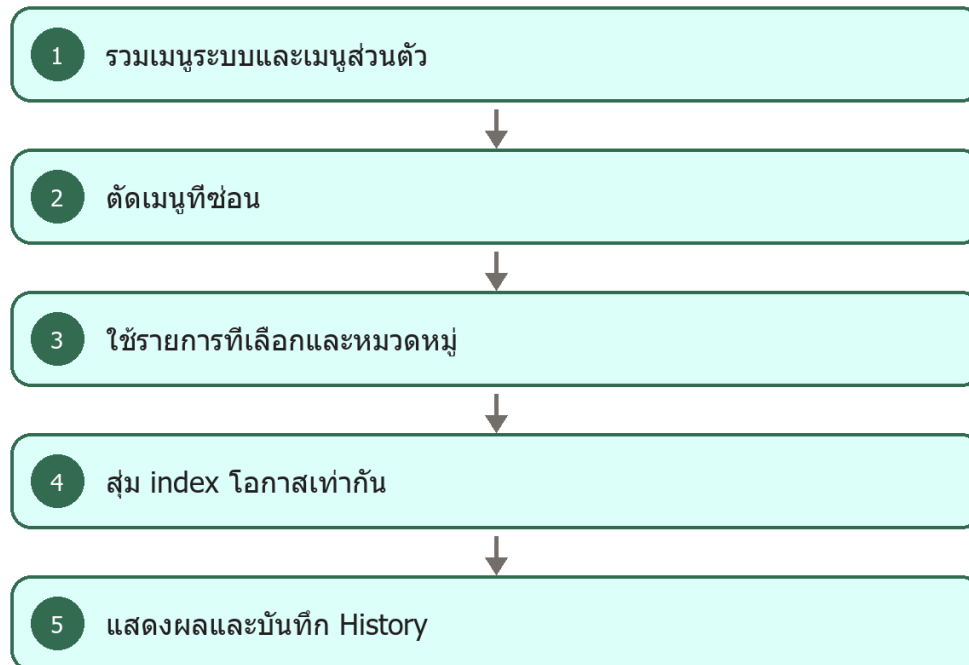
การเก็บ Session

1. Native เก็บ session ใน Expo SecureStore โดยแบ่งข้อมูลเป็นชิ้นละ 1500 ตัวอักษร
2. Web เก็บ session ในหน่วยความจำเท่านั้น ไม่เขียน token ลง localStorage
3. เมื่อแอป Active จะเริ่ม auto refresh และเมื่อไม่ Active จะหยุด
4. onAuthStateChange กระตุ้นการโหลดโปรไฟล์ใหม่ โดยหลีกเลี่ยงการเรียก Supabase ซ้อนใน auth lock

การออกแบบสำคัญคือ service role key อยู่ใน Edge Functions เท่านั้น แอปมือถือใช้ publishable key และ session ของผู้ใช้การมีปุ่มซ่อนหรือแสดงใน UI จึงไม่ใช่ตัวควบคุมสิทธิ์หลัก

ระบบสุ่มอาหาร

Flow การสุ่ม Solo



การสร้างรายการสำหรับสุ่ม

1. โหลด foods ซึ่งเป็นเมนูระบบ และ user_foods ของผู้ใช้พร้อมกัน
2. โหลด food_preferences ของผู้ใช้
3. ตัดเมนูที่ is_hidden เป็น true
4. สำหรับเมนูระบบ ตัดรายการที่ is_selected เป็น false
5. ถ้าเลือกหมวดหมู่ ให้เหลือเฉพาะหมวดหมู่ที่เลือก เมนูส่วนตัวถูกนำมารวมอัตโนมัติเมื่อไม่ถูกซ่อน
6. ถ้ารายการสุดท้ายไม่ว่าง ให้สุ่ม index ด้วย floor Math random คูณจำนวนรายการ
7. แสดงผลด้วยแอนิเมชันพลิกการ์ด และบันทึก history mode solo

หลักคณิตศาสตร์ของ Solo

$\text{index} = \text{floor}(\text{random}() * N)$ โดย $\text{random}()$ อยู่ในช่วง 0 ถึงน้อยกว่า 1 และ N คือจำนวนเมนูที่ผ่านตัวกรอง แต่ละเมนูจึงมีโอกาส 1 ต่อ N

หน้า Home ใช้หลักการเดียวกัน แต่สุ่มจากรายการรวมที่ผ่าน hidden และ selected โดยไม่ใช้ตัวกรองหมวดหมู่

หลักการตัดสิน Party

1. ทุกคนโหวต Like หรือ Skip ครบทุกเมนู
2. คะแนนหนึ่งคนต่อหนึ่งเมนูเก็บใน room_votes โดย Primary Key room_id user_id food_id ทำให้ส่งซ้ำแล้วไม่เปลี่ยนคะแนนเดิม
3. เมื่อจำนวนคะแนนเท่ากับจำนวนผู้เล่นคูณจำนวนเมนู ระบบหากลุ่มเมนูที่จำนวน Like เท่ากับจำนวนผู้เล่น
4. ถ้าไม่มีกลุ่มที่ทุกคน Like ผลคือ no_match
5. ถ้ามีหนึ่งรายการ รายการนั้นชนะ ถ้ามีหลายรายการ PostgreSQL ใช้ order by random limit 1
เลือกหนึ่งรายการแบบสุ่มจากผู้ชนะร่วม

ระบบไม่ได้ใช้ AI หรือ Machine Learning ในการสุ่มอาหาร เป็น pseudo random ของ JavaScript สำหรับ Solo และ PostgreSQL random สำหรับการตัดสินกรณีผู้ชนะร่วมใน Party

ระบบห้อง Party

Flow ห้อง Party



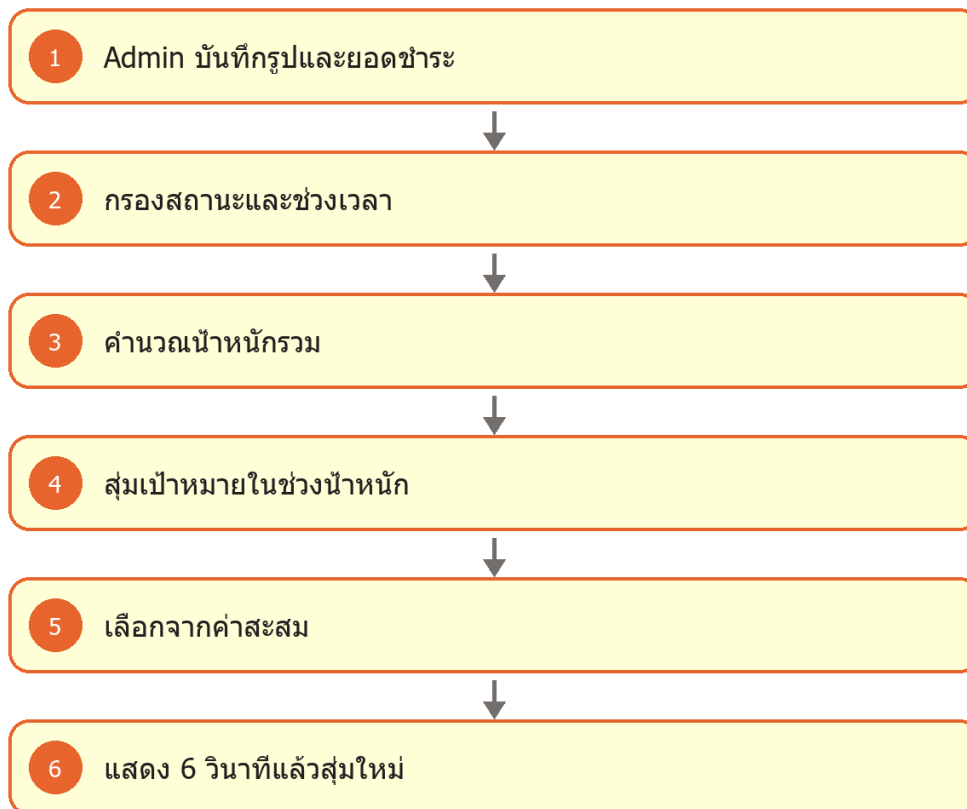
ช่วง	การทำงาน
สร้างห้อง	RPC party action create สร้างเลข 6 หลักด้วย PostgreSQL random พยายามได้สูงสุด 10 ครั้งหากชน ดัง capacity 4 version 2 และหมดอายุใน 2 ชั่วโมง
เข้าห้อง	ตรวจรหัส 6 หลัก สถานะ waiting เวลาหมดอายุ และจำนวนผู้เล่น ใช้ user id กันผู้ใช้คนเดียวเข้าในห้อง
ล็อบบี้	แสดงสมาชิก คัดลอกหรือแชร์รหัส และเพิ่มเมนูเองได้สูงสุด 50 รายการ ชื่อไม่เกิน 30 ตัวอักษร
เริ่มเกม	เฉพาะ Host และต้องมีอย่างน้อย 2 คน ฐานข้อมูลล็อกแถวห้องและ snapshot เมนูลง room_foods ถ้ามีเมนูห้องจะใช้เฉพาะรายการนั้น ไม่เช่นนั้นใช้ foods
ซิงค์	Realtime UPDATE ของ rooms ใช้เป็นสัญญาณให้ refresh ส่วน snapshot จาก RPC เป็นข้อมูลจริง และมี polling ทุก 2 วินาทีเพื่อคู่จาก event ที่หลุด
โหวต	ทุกคำสั่งผ่าน RPC เดียว มี timeout 15 วินาที ไม่เลือกการดบแบบ optimistic จน server ยืนยัน
สรุปผล	เมื่อคะแนนครบ ฐานข้อมูลหาจุดตัด Like ของผู้เล่นทั้งหมด อัปเดตห้องเป็น done และบันทึก history ให้ผู้เล่นทุกคน
ออกจากห้อง	Host ออกจาก waiting หรือผู้เล่นออกระหว่าง playing จะยกเลิกรอบ ส่วนสถานะสมาชิกบันทึก left_at

เหตุผลที่ใช้ PostgreSQL RPC

การสร้างห้อง เริ่มเกม โหวต ออกจากห้อง และสรุปผลต้องเปลี่ยนหลายตารางพร้อมกัน RPC party ทำให้ฐานข้อมูลล็อกแถว rooms และทำทุกชั้นใน transaction เดียว จึงลดปัญหาผู้เล่นกดพร้อมกัน คะแนนซ้ำ หรือมีผู้สรุปผลหลายเครื่อง

ระบบโฆษณา

Flow โฆษณา



สิทธิ์และการจัดการ

- สิทธิ์ Admin มาจากแถวใน admin_users ไม่ได้มาจาก user metadata
- Settings แสดงปุ่ม Admin เฉพาะผู้ที่อ่านแถวของตนเองได้
- AdminAds รองรับเพิ่ม ดู แก้ไข เปิดหรือปิด และลบโฆษณา
- รูปโฆษณาเลือกอัตราส่วน 16 ต่อ 9 และเก็บใน bucket advertisements ภายใต้โฟลเดอร์ user id

หลักการคัดเลือก

หน้าแรกอ่านเฉพาะ is_active เท่ากับ true starts_at ไม่เกินเวลาปัจจุบัน และ ends_at ยังไม่หมดอายุหรือไม่มีค่า

$probability(ad\ i) = \frac{payment_amount\ i}{\text{ผลรวม } payment_amount \text{ ของโฆษณาที่เข้าเงื่อนไข}}$

ถ้าร้าน A จ่าย 1000 บาท และร้าน B จ่าย 500 บาท ร้าน A มีโอกาสประมาณ 66.67 เปอร์เซนต์ และร้าน B ประมาณ 33.33 เปอร์เซนต์ต่อการเลือกหนึ่งครั้ง

AdCarousel เลือกใหม่ทุก 6000 ms พร้อม fade out 220 ms และ fade in 320 ms การเลือกแต่ละครั้งเป็นอิสระ
จึงอาจเห็นโฆษณาเดิมติดกันได้

เมื่อไม่มีโฆษณาที่ใช้ได้ จะแสดงพื้นที่ว่างสำหรับโปรโมทร้านและเบอร์ติดต่อ 097-9253802

ยอดชำระต้องมากกว่า 0 และไม่เกิน 10000000000 ลิงก์ปลายทางต้องเป็น http หรือ https และรูป URL ต้องเป็น https

ระบบเมนู โปรด ประวัติ ค้นหา และโปรไฟล์

เมนูอาหาร

- foods เป็นรายการระบบ อ่านได้โดยผู้ใช้ที่เข้าสู่ระบบ
- user_foods เป็นรายการส่วนตัว เจ้าของเพิ่ม แก้ไข และลบได้
- AllFoods รวมสองแหล่งและแสดง source เพื่อแยกเมนูระบบกับของผู้ใช้
- ผู้ใช้ซ่อนเมนูได้โดยบันทึก food_preferences แทนการลบเมนูระบบ
- Solo มีตัวเลือก is_selected แยกจาก is_hidden สำหรับกำหนด pool เมนูระบบ

เมนูโปรด

- การบันทึกโปรดเรียก RPC save_favorite
- RPC ล็อกแถวผู้ใช้และตรวจสอบชื่อเดิมก่อน insert เพื่อลดรายการซ้ำจากการกดพร้อมกัน
- หนักรายการโปรดรวม image ที่บันทึกกับรูปจาก foods และลบได้เฉพาะแถวของตนเอง

ประวัติ

- Solo บันทึกหลังเปิดผลส้ม Party บันทึกตอนฐานข้อมูลสรุปผู้ชนะ
- หน้า History เรียงใหม่ไปเก่าและแสดงวันที่ เวลา หมวด และรูป
- ปุ่มล้างประวัติปัจจุบันล้างเฉพาะรายการบนหน้าจอ ไม่ลบข้อมูลในฐานข้อมูล

การค้นหา

- รอ 400 ms หลังพิมพ์ก่อนค้นหาเพื่อลดจำนวน request
- ใช้ ilike กับชื่ออาหาร จึงไม่สนตัวพิมพ์เล็กใหญ่
- ผู้ใช้ปกติค้นทั้ง foods และ user_foods ของตัวเอง Guest ค้นเฉพาะ foods

โปรไฟล์

- ผู้ใช้ปกติแก้ไขชื่อที่แสดงและรูปโปรไฟล์ได้ แต่ Username อ่านอย่างเดียว
- รูปเลือกจาก Gallery หรือกล้องและบันทึก URL ใน public.users
- Guest ไม่สามารถแก้ไขข้อมูลโปรไฟล์ได้

ระบบแผนที่และร้านใกล้เคียง

1. ขอ foreground location permission

2. อ่าน GPS แบบ Balanced accuracy และ reverse geocode เป็นชื่อพื้นที่
3. ถ้าเปิดจากผลสุ่ม ใช้รัศมี 5000 เมตร ถ้าเปิดทั่วไปใช้ 3000 เมตร
4. ส่ง Overpass QL ไปยัง overpass-api.de และสำรองที่ overpass.private.coffee
5. รับ node way และ relation ที่เป็น restaurant fast_food cafe หรือ food_court
6. คำนวณระยะทางด้วยสูตร Haversine และเก็บสูงสุด 30 ร้าน
7. เมื่อมีชื่ออาหาร ให้คะแนนชื่อร้านตรง 100 คะแนน cuisine ตรง 60 คะแนน และเมนูอนุมานตรง 30 คะแนน แล้วใช้ระยะทางตัดสินลำดับถัดไป
8. ถ้า GPS ถูกปฏิเสธ API ล้มเหลว หรือไม่พบร้าน จะแสดงข้อมูลตัวอย่างเพื่อให้เห็นการทำงาน
9. ปุ่มเส้นทางเปิด Google Maps ด้วย latitude และ longitude ของร้าน

ความหมายของผลลัพธ์

OpenStreetMap มักมีประเภทร้านและ cuisine แต่ไม่ได้รับรองว่ามีรายการเมนูจริงทุกจุด เมนูที่แสดงจึงเป็นการอนุมานจาก cuisine และ amenity ไม่ใช่ข้อมูลเมนูจากร้านโดยตรง

user_foods เก็บ restaurant_name lat และ lng ได้ แต่ NearbyMap ปัจจุบันยังไม่ได้ผสมผสานฟังก์ชันเหล่านี้เข้ากับผล Overpass

ระบบรูปภาพและ Storage

1. Expo Image Picker ขอสิทธิ์และคืน base64 โดยเลือกแค่ crop รูปภาพ 0.7
2. imageBytes ตรวจว่ามี base64 ที่ถูกต้องและขนาดไม่เกิน 5 MB
3. ตรวจ magic bytes เพื่อยอมรับเฉพาะ JPEG PNG หรือ WebP ไม่เชื่อ MIME จากชื่อไฟล์
4. สร้าง path เป็น userId ตามด้วย timestamp และค่าสุ่ม แล้ว upload แบบ upsert false
5. เก็บ public URL ในตารางที่เกี่ยวข้อง
6. ถ้าเขียนฐานข้อมูลล้มเหลวหลังอัปโหลด discardUpload จะลบไฟล์ใหม่เพื่อลดไฟล์ก้าวร้าย
7. Storage policy จำกัดการเขียนไว้ที่โฟลเดอร์ user id และโฆษณาต้องผ่าน is_admin

โครงสร้างข้อมูล

ตาราง public ที่แอปใช้งานแบ่งเป็นข้อมูลผู้ใช้ ข้อมูลเมนู ประวัติ ห้อง Party และการดูแลโฆษณา ตาราง Party รุ่นใหม่ไม่เปิดให้ Client เขียนโดยตรง แต่ให้ RPC เป็นผู้จัดการ

ตาราง	ข้อมูลหลัก	เจ้าของหรือการเข้าถึง
users	โปรไฟล์ ชื่อ Username Email Guest และรูป	อ่านและแก้ไขเฉพาะตนเอง โดย Guest แก้มได้
foods	เมนูระบบ ชื่อ หมวด ราคา รูป	ผู้ใช้ที่เข้าสู่ระบบอ่านได้
user_foods	เมนูส่วนตัว ร้าน พิกัด และรูป	เจ้าของ CRUD
food_preferences	hidden และ selected ต่อผู้ใช้ต่อเมนู	เจ้าของ CRUD

ตาราง	ข้อมูลหลัก	เจ้าของหรือการเข้าถึง
favorites	ชื่อ หมวด และรูปเมนูโปรด	เจ้าของอ่านและลบ การเพิ่มผ่าน RPC
history	ผลสุม mode solo หรือ party และเวลา	เจ้าของ CRUD ตาม policy แต่ UI ล้างเฉพาะ local
rooms	รหัส สถานะ Host ความจุ เมนูห้อง วันหมดอายุ และผล	สมาชิกอ่านผ่าน policy การเขียนผ่าน RPC
participants	สมาชิก ชื่อ user id เวลาเข้าออก	ไม่มี Data API policy โดยตรง จัดการผ่าน RPC
room_foods	snapshot เมนูต่อรอบ	ไม่มี Data API policy โดยตรง จัดการผ่าน RPC
room_votes	Like หรือ Skip ต่อผู้ใช้ต่อเมนู	ไม่มี Data API policy โดยตรง จัดการผ่าน RPC
swipes	ข้อมูล Party รุนเก่า	คงไว้เพื่อ compatibility แต่ flow ใหม่ใช้ room_votes
admin_users	รายชื่อผู้ดูแล	ผู้ใช้เห็นได้เฉพาะแอดมินของตน
advertisements	รูป ลิงก์ ยอดชำระ ช่วงเวลา และสถานะ	ผู้ใช้เห็นรายการ active Admin CRUD

ความปลอดภัย

ชั้นความปลอดภัย	วิธีที่ใช้
รหัสผ่าน	Supabase Auth สำหรับบัญชีใหม่ รหัสผ่านขั้นต่ำ 12 ตัวและไม่เกิน 72 bytes บัญชีเก่า migrate ด้วย bcrypt ฟังก์ชัน Edge Function
OTP	Email PIN 6 หลัก Verify ด้วย verifyOtp โปรไฟล์ยังไม่ถูกสร้างจนยืนยันสำเร็จ
Session	SecureStore บนมือถือคือ Memory only บน Web และ auto refresh ตาม AppState
Rate limit	สมัคร 5 ครั้งต่อ 15 นาทีต่อ key และ 100 ครั้งต่อนาทีรวม Login จำกัดผ่าน login_attempt Party create หรือ join 20 ครั้งต่อ 10 นาที
Enumeration	Login ตอบข้อความผิดเหมือนกันและหน่วงเวลาอย่างน้อยประมาณ 500 ms
RLS	ตารางผู้ใช้และข้อมูลส่วนตัวทุก auth.uid ส่วนข้อมูล Party เขียนผ่าน RPC
Service role	อยู่ใน Edge Function เท่านั้น ไม่ฝังในแอป Client ใช้ publishable key
Storage	จำกัดชนิดไฟล์ ขนาด โฟลเดอร์เจ้าของ และสิทธิ์ Admin สำหรับโฆษณา
Concurrency	Party ล็อกแถวห้อง room_votes มี composite primary key และ finalization เกิดใน transaction เดียว

ความเสถียรและการกู้คืน

- Party ใช้ snapshot จาก RPC เป็นแหล่งข้อมูลจริง Realtime เพียงแจ้งให้ refresh และ polling ทุก 2 วินาทีช่วยกู้ event ที่หลุด
- partyAction ยกเลิก request ที่เกิน 15 วินาที และ hook กันการอ่านหรือเขียนซ้อน
- การโหลดไม่เลื่อนการ์ดล่วงหน้าก่อน server ตอบ จึงไม่เกิด UI เดินหน้าทั้งที่คะแนนไม่ถูกบันทึก
- การอัปโหลดรูปใช้ upsert false และลบไฟล์ใหม่เมื่อบันทึกข้อมูลไม่สำเร็จ

- NearbyMap มี Overpass สำรองสอง endpoint และ demo fallback
- AuthProvider ใช้ generation counter ป้องกันผล request เก่ามาทับ session ใหม่

สถานะระบบที่ตรวจพบ

Supabase โปรเจกต์ what2eat-backend อยู่ที่ ap-southeast-1 สถานะ ACTIVE_HEALTHY และใช้ PostgreSQL 17.6 ณ วันที่ 2026-09-22

ข้อมูล	จำนวนแถว
users	16
foods	8
user_foods	4
favorites	6
history	139
rooms	37
participants	55
room_foods	0
room_votes	0
admin_users	0
advertisements	0
food_preferences	1

ผลการตรวจสอบ

- Local automated tests 12 จาก 12 ผ่าน
- Expo Doctor 21 จาก 21 ผ่าน
- Android JavaScript bundle ผ่าน 1411 modules
- git diff check ผ่าน

ข้อจำกัดและสิ่งที่ควรทำต่อ

1. admin_users และ advertisements ยังไม่มีข้อมูลจริง ณ วันที่ตรวจ จึงยังไม่มีผู้ใช้เปิดหน้า Admin และหน้าแรกจะแสดงช่องติดต่อโฆษณา
2. Big Party สูงสุด 20 คนยังไม่เปิดและไม่มีระบบชำระเงิน ห้องใช้งานจริงจำกัด 4 คน
3. Map ใช้ข้อมูลชุมชน OpenStreetMap รายชื่อร้านหรือ cuisine อาจไม่ครบ และเมนูเป็นการอนุมาน

4. พิกัดร้านที่บันทึกกับ user_foods ยังไม่ถูกนำไปแสดงร่วมกับผลร้านใกล้เคียง
5. ปุ่มล้างประวัติซ่อนข้อมูลบนหน้าจอเท่านั้น ไม่ลบฐานข้อมูล
6. การนับ 30 วินาทีในหน้า PIN ต้องตั้ง Email max frequency ส่ง Supabase เป็น 30 วินาทีด้วย มิฉะนั้น server อาจยังบังคับค่าที่ยาวกว่า
7. Supabase Advisor รายงาน Leaked Password Protection ยังปิดอยู่ ควรเปิดก่อนใช้งานจริง
8. Advisor เตือน policy ที่ใช้ role authenticated อาจครอบคลุม Anonymous user เพราะ Guest ใช้ Anonymous Auth ต้องคง ownership check ทุก policy และทบทวนสิทธิ์ที่ Guest ควรมี
9. ตาราง participants room_foods room_votes และ swipes เปิด RLS แต่ไม่มี policy โดยตรง ซึ่งเป็นการปิด Data API โดยตั้งใจเพราะ flow ใหม่เขียนผ่าน RPC เท่านั้น ควรบันทึกเจตนาไว้ในเอกสารการดูแลระบบ
10. โฆษณาใช้ payment_amount เป็นน้ำหนักการแสดงผล ไม่ใช่ระบบประมวล งบที่ใช้จริง หรือการคิดค่าบริการตาม impression

วิธีรันและตรวจสอบระบบ

งาน	คำสั่ง	หมายเหตุ
ติดตั้ง	npm install	ติดตั้ง dependency ตาม package lock
รันใน WiFi เดียวกัน	npx expo start	สแกน QR ด้วย Expo Go
ทดสอบบนเครื่อง	npx expo start --tunnel	เครื่องพัฒนาต้องเปิด Metro และเชื่อมต่ออินเทอร์เน็ต
ทดสอบอัตโนมัติ	npm test	ตรวจ 12 invariants และ weighted ads
ทดสอบ Supabase จริง	npm run test:security	ตรวจ anonymous denial และ Edge Function validation
ตรวจ Expo	npx expo-doctor	ตรวจ dependency และ configuration
Android bundle	npx expo export --platform android	ตรวจว่า Metro bundle สำเร็จ

อภิธานศัพท์

คำ	ความหมายในระบบนี้
RLS	Row Level Security กฎใน PostgreSQL ที่กรองสิทธิ์ทุก query ตามผู้ใช้
RPC	การเรียก PostgreSQL Function ผ่าน Supabase เช่น party และ save_favorite
Edge Function	โค้ด Deno บน Supabase สำหรับงานที่ต้องใช้ secret หรือควบคุมฝั่ง server
Snapshot	ภาพสถานะห้องล่าสุดที่ RPC ส่งกลับ ทั้งห้อง สมาชิก เมนู และคะแนนของผู้ใช้
Realtime	ช่องแจ้ง event จากฐานข้อมูล ใน Party ใช้กระตุ้นให้โหลด snapshot ใหม่
OTP	One Time Password ในที่นี้คือ PIN Email 6 หลัก
Weighted random	การสุ่มที่โอกาสไม่เท่ากัน โดยสัดส่วนตามน้ำหนัก
Uniform random	การสุ่มที่ทุกรายการใน pool มีโอกาสเท่ากัน
Overpass API	บริการ query ข้อมูล OpenStreetMap สำหรับหาเส้นทางใกล้เคียง

แหล่งอ้างอิง

1. ซอร์สโค้ด Joykin Branch v1ice D:/Code/what2eat
2. Supabase Row Level Security <https://supabase.com/docs/guides/database/postgres/row-level-security>
3. Supabase Storage Access Control <https://supabase.com/docs/guides/storage/security/access-control>
4. Supabase Email Templates <https://supabase.com/docs/guides/auth/auth-email-templates>
5. Supabase Realtime Postgres Changes <https://supabase.com/docs/guides/realtime/postgres-changes>
6. Expo SDK 57 Reference <https://docs.expo.dev/versions/v57.0.0/>
7. OpenStreetMap Overpass API https://wiki.openstreetmap.org/wiki/Overpass_API

ไฟล์หลักที่ใช้ตรวจสอบ

- App.js
- context/AuthContext.js
- screens/HomeScreen.js และ screens/SoloScreen.js
- screens/PartyScreen.js screens/LobbyScreen.js screens/SwipeScreen.js screens/ResultScreen.js
- services/party.js hooks/usePartyRoom.js
- services/foodPreferences.js services/nearbyPlaces.js utils/weightedAds.js
- supabase/functions/account-register/index.ts และ account-login/index.ts
- database/secure_auth_and_party.sql database/registration_otp.sql database/dynamic_ads_and_food_preferences.sql
- utils/imageUpload.js utils/sessionStorage.js components/AdCarousel.js